TALLINN UNIVERSITY OF TECHNOLOGY
School of Information Technologies

Manana Bebia 234147IVSB

Machine Learning Approach to Risk-Based Vulnerability Prioritization Using Public Data

Bachelor's thesis

Supervisor: Fuad Budagov

MBA

Tallinn 2026

TALLINNA TEHNIKAÜLIKOOL

Infotehnoloogia teaduskond

Manana Bebia 234147IVSB

Masinõppepõhine riskipõhise haavatavuste prioriseerimise lähenemine avalike andmete põhjal

Bakalaureusetöö

Juhendaja: Fuad Budagov

MBA

Tallinn 2026

Author’s declaration of originality

I hereby certify that I am the sole author of this thesis. All the used materials, references to the literature and the work of others have been referred to. This thesis has not been presented for examination anywhere else.

Author: Manana Bebia

11.05.2026

Abstract

This thesis addresses the problem of vulnerability prioritization in cybersecurity, where traditional approaches rely primarily on CVSS scores that reflect technical severity but do not adequately represent real-world risk. As a result, organizations may focus remediation efforts on vulnerabilities that are less critical, while overlooking vulnerabilities that are actively exploited or affect critical assets.

The aim of this thesis is to develop and evaluate a risk-based vulnerability prioritization approach that combines vulnerability severity, exploitability information, and asset criticality. A machine learning–based prototype is proposed to improve vulnerability prioritization compared to traditional CVSS-only ranking methods.

The methodology is based on a data-driven experimental approach using publicly available data sources. CVSS metrics are obtained from the National Vulnerability Database, while real-world exploitation information is derived from the CISA Known Exploited Vulnerabilities catalog. In addition, a synthetic asset dataset is constructed to represent different levels of asset criticality. Logistic Regression and Random Forest models are trained to classify vulnerabilities according to their risk level, and the performance of the models is evaluated using precision and recall metrics.

The results demonstrate that integrating exploitability and asset context into vulnerability prioritization improves the identification of high-risk vulnerabilities compared to CVSS based approaches. The developed prototype illustrates the potential of machine learning–assisted risk-based vulnerability prioritization using public data.

This thesis is written in English and is 46 pages long, including 6 chapters, 6 figures and 3 table.

Lühikokkuvõte

MASINÕPPEPÕHINE RISKIPÕHISE HAAVATAVUSTE PRIORISEERIMISE LÄHENEMINE AVALIKE ANDMETE PÕHJAL

Käesolev lõputöö käsitleb küberturvalisuse valdkonnas esinevat haavatavuste prioriseerimise probleemi, kus traditsioonilised lähenemised tuginevad peamiselt CVSS skooridele, mis kajastavad tehnilist tõsidust, kuid ei peegelda piisavalt tegelikku riski. Selle tulemusena võivad organisatsioonid keskenduda vähem kriitiliste haavatavuste kõrvaldamisele, samal ajal kui aktiivselt ära kasutatavad või kriitilisi varasid mõjutavad haavatavused jäävad tähelepanuta.

Lõputöö eesmärk on välja töötada ja hinnata riskipõhist haavatavuste prioriseerimise lähenemist, mis ühendab haavatavuse tõsiduse, ärakasutamise info ning vara kriitilisuse. Selleks pakutakse välja masinõppel põhinev prototüüp, mille eesmärk on parandada prioriseerimisotsuseid võrreldes ainult CVSS-skooridel põhinevate meetoditega.

Metoodika põhineb andmepõhisel eksperimentaalsel lähenemisel, kasutades avalikult kättesaadavaid andmeallikaid. CVSS-mõõdikud pärinevad National Vulnerability Database'ist ning tegeliku ärakasutamise info CISA Known Exploited Vulnerabilities kataloogist. Lisaks luuakse sünteetiline varade andmestik, mis esindab erinevaid vara kriitilisuse tasemeid. Haavatavuste riskitaseme klassifitseerimiseks kasutatakse logistilist regressiooni ja juhumetsa mudeleid, mille tulemuslikkust hinnatakse täpsuse ja tundlikkuse mõõdikutega.

Tulemused näitavad, et ärakasutatavuse ja vara konteksti kaasamine parandab kõrge riskiga haavatavuste tuvastamist võrreldes traditsiooniliste CVSS-põhiste lähenemistega. Väljatöötatud prototüüp demonstreerib masinõppel põhineva riskipõhise haavatavuste prioriseerimise potentsiaali avalike andmete kasutamisel.

Lõputöö on kirjutatud inglise keeles ning sisaldab teksti 46 leheküljel, 6 peatükki, 5 joonist, 3 tabelit.

List of abbreviations and terms

AI	Artificial Intelligence
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
EPSS	Exploit Prediction Scoring System
FP	False Positive
KEV	Known Exploited Vulnerabilities
LR	Logistic Regression
ML	Machine Learning
NVD	National Vulnerability Database
RF	Random Forest
TP	True Positive

Table of contents

List of figures. 9

List of tables 10

1 Introduction 11

1.1 Problem Statement 11

1.2 Research Goal 12

1.3 Scope and Limitations 12

1.4 Thesis Structure 12

2 Theoretical Background 14

2.1 Vulnerability Management and CVSS 14

2.2 Limitations of Severity-Based Prioritization 14

2.2.1 Additional Problems of CVSS-Based Prioritization 15

2.3 Risk-Based Vulnerability Management 16

2.4 Exploitability Indicators: KEV and EPSS 16

2.4.1 EPSS as a Modern Alternative to Static Severity Scoring 17

2.5 Machine Learning in Vulnerability Exploitation Prediction 18

2.5.1 Criticism of Existing Machine Learning Approaches 18

2.6 Related Work and Research Contribution 19

3 Methodology 21

3.1 Research Design 21

3.2 Tool Development 22

3.2.1 Strategy 22

3.2.2 Model Selection 23

3.2.3 Logging and Analysis 23

3.2.4 Why Random Forest Was More Effective 23

3.3 Testing and Evaluation 24

3.3.1 Test Case Environment 24
3.3.2 Evaluation Framework 25
3.3.3 Experimental Setup 25
4 Results 26
4.1 Dataset Overview 26
4.2 Baseline Performance (CVSS Threshold) 26
4.3 Machine Learning Model Performance 27
4.4 Feature Importance Analysis 28
4.5 Top-N Prioritization Analysis 28
4.6 Extended Practical Analysis and Real-World Application 29
5 Discussion 31
5.1 Interpretation of Results 31
5.2 Comparison with Existing Approaches 31
5.2.1 Expanded Critical Comparison with Existing Research 31
5.3 Practical Implications 32
5.4 Limitations of the Study 33
5.5 Ethical and Operational Considerations 33
6 Conclusion 35
6.1 Future Work 35
References 36
Appendix 1 – Non-exclusive licence for reproduction and publication of a graduation thesis 39
Appendix 2 - Main Training and Evaluation Script 40
Appendix 3 - Data Loading and Source Integration Script 44
Appendix 4 - Feature Construction and Labeling Logic 46

List of figures.

Figure 1 Methodology Workflow for Risk-Based Prioritization 21
Figure 2 Multi-Factor Risk Prioritization Process 22
Figure 3 CVSS vs Risk-Based Prioritization Comparison 24
Figure 4 Class Distribution of Vulnerabilities 26
Figure 5 Confusion Matrix of CVSS-Based Baseline Classification 27
Figure 6 Feature Importance of Random Forest Model 28

List of tables

Table 1 Comparison of Vulnerability Prioritization Indicators..... 18
Table 2 Top-N KEV Detection Comparison..... 29
Table 3 Comparison of Prioritization Approaches..... 29

1 Introduction

Cybersecurity vulnerability management has become a critical component of modern organizational security strategies. Thousands of new software vulnerabilities are disclosed annually, creating increasing pressure on organizations to identify, assess, and remediate security weaknesses efficiently. Due to limited resources and operational constraints, not all vulnerabilities can be addressed immediately. Therefore, effective prioritization mechanisms are essential.

The Common Vulnerability Scoring System (CVSS) is widely used to assess and communicate the technical severity of vulnerabilities [1]. CVSS provides a standardized framework consisting of Base, Temporal, and Environmental metrics that produce a numerical score between 0.0 and 10.0 [1]. While CVSS offers transparency and vendorneutral scoring, it is designed to measure intrinsic technical characteristics and impact severity rather than real-world exploitation likelihood [1].

Recent initiatives highlight the limitations of severity-only prioritization. The Known Exploited Vulnerabilities (KEV) catalog maintained by the Cybersecurity and Infrastructure Security Agency (CISA) provides a list of vulnerabilities confirmed to be exploited in the wild [2]. Analysis of KEV data suggests that only a subset of disclosed vulnerabilities are actively exploited, indicating that high severity does not necessarily imply high risk.

Similarly, the Exploit Prediction Scoring System (EPSS), developed by FIRST, estimates the probability that a vulnerability will be exploited within a defined time window [3]. Unlike CVSS, which measures impact severity, EPSS provides a probabilistic risk indicator.

Risk-based prioritization approaches argue that vulnerability management should incorporate exploitation likelihood, threat intelligence, and contextual business factors rather than relying solely on severity scores [4].

These developments suggest a growing gap between traditional severity-based prioritization and modern risk-aware approaches. This thesis addresses that gap by investigating whether enhanced, risk-based prioritization mechanisms can improve remediation decision-making compared to traditional CVSS-based ranking.

1.1 Problem Statement

Organizations commonly prioritize vulnerabilities based primarily on CVSS Base Scores [1]. However, CVSS does not explicitly model exploitation probability or real-world attacker behavior.

Research has shown that vulnerability exploitation does not correlate perfectly with severity metrics. Sabottke et al. demonstrated that external signals and contextual indicators can significantly improve prediction of vulnerability exploitation events [4]. Furthermore, real-world exploitation evidence, such as the CISA KEV catalog [2], demonstrates that only a relatively small fraction of vulnerabilities are actively exploited.

As a result, organizations may allocate remediation resources inefficiently by prioritizing technically severe but low-exploitation vulnerabilities while overlooking vulnerabilities with higher real-world risk.

The central problem addressed in this thesis is:

How can vulnerability prioritization be improved beyond traditional CVSS severity-based ranking in order to better reflect real-world exploitation risk?

1.2 Research Goal

The goal of this thesis is to design and evaluate a risk-based vulnerability prioritization approach and compare its effectiveness with traditional CVSS-based ranking.

Specifically, this thesis aims to:

- Analyze the structure and limitations of CVSS scoring [1],
- Examine exploitation evidence from the CISA KEV catalog [2],
- Investigate probabilistic prediction approaches such as EPSS [3],
- Explore machine learning–based exploitation prediction research [4]
- Develop a prototype prioritization framework incorporating exploitation-related indicators,
- Evaluate whether the proposed approach aligns more closely with real-world exploitation data compared to CVSS-only ranking.

1.3 Scope and Limitations

This research focuses exclusively on publicly available vulnerability data sources, including CVSS v3.1 metrics [1], the CISA KEV catalog [2], and EPSS probability scores [3].

The study is limited to vulnerabilities identified by CVE identifiers and does not incorporate proprietary enterprise security data. The developed framework is intended as a proof-of-concept model rather than a production-ready security system.

Additionally, evaluation is conducted using historical datasets and does not include live deployment within an operational enterprise environment. Therefore, conclusions are analytical rather than operational in nature.

Despite these limitations, this research contributes to the understanding of risk-based vulnerability prioritization and provides an empirical comparison between severity-based and exploitation-aware approaches.

1.4 Thesis Structure

This thesis is organized into four main chapters. Chapter 1 introduces the research problem, defines the objectives, and outlines the scope and limitations of the study. It also

highlights the need for improved vulnerability prioritization approaches that extend beyond traditional severity-based methods.

Chapter 2 presents the theoretical background and literature review. It examines vulnerability management practices, the Common Vulnerability Scoring System (CVSS), and the limitations of severity-based prioritization. Furthermore, it reviews risk-based vulnerability management approaches, exploitation indicators such as KEV and EPSS, and machine learning techniques used in vulnerability exploitation prediction.

Chapter 3 describes the research methodology and practical implementation. It outlines research design, data sources, prototype development, machine learning models, and evaluation framework used to compare CVSS-based and risk-based prioritization approaches.

Chapter 4 presents the experimental results and analysis. It evaluates the performance of the baseline and machine learning models, analyzes feature importance, and assesses prioritization effectiveness using Top-N evaluation.

Finally, the thesis concludes with a summary of findings and recommendations for future research.

2 Theoretical Background

This chapter presents the theoretical foundations and related research relevant to vulnerability prioritization. It first introduces traditional vulnerability severity assessment through CVSS, then discusses its limitations, and finally examines risk-based and exploitation-aware approaches including KEV and EPSS.

2.1 Vulnerability Management and CVSS

Vulnerability management is a structured process aimed at identifying, assessing, prioritizing, and remediating security weaknesses in software and systems. Organizations rely on vulnerability databases and standardized scoring mechanisms to evaluate the potential impact of disclosed vulnerabilities.

The most widely adopted framework for vulnerability severity assessment is the Common Vulnerability Scoring System (CVSS) [1]. CVSS provides a standardized methodology for calculating a numerical score between 0.0 and 10.0, representing the technical severity of a vulnerability.

According to the CVSS v3.1 specification, the scoring system consists of three metric groups [1]:

- Base Metrics, representing intrinsic characteristics of a vulnerability.
- Temporal Metrics, reflecting characteristics that change over time.
- Environmental Metrics**,** accounting for organization-specific context.

The Base Score is derived from factors such as attack vector, attack complexity, required privileges, user interaction, scope, and impact on confidentiality, integrity, and availability [1]. The resulting score is categorized into qualitative levels (Low, Medium, High, Critical).

Due to its standardization and availability through the National Vulnerability Database (NVD), CVSS has become the default prioritization mechanism in many vulnerability management programs.

However, CVSS was designed to measure severity rather than exploitation probability or contextual risk. This distinction forms the basis of the research problem addressed in this thesis.

2.2 Limitations of Severity-Based Prioritization

Although CVSS provides a consistent and transparent severity metric, several studies have shown that technical severity does not necessarily correlate with real-world exploitation.

Empirical research by Sabottke et al. demonstrated that vulnerability exploitation can be better predicted by incorporating contextual and external indicators rather than relying

solely on severity metrics [5]. Their findings suggest that factors beyond CVSS scoring contribute significantly to exploitation likelihood.

Furthermore, real-world exploitation evidence maintained by the Cybersecurity and Infrastructure Security Agency (CISA) highlights the discrepancy between severity and active exploitation. The Known Exploited Vulnerabilities (KEV) catalog lists vulnerabilities confirmed to be exploited in the wild [2]. Analysis of KEV data shows that only a subset of disclosed vulnerabilities are actively exploited, and not all high-severity vulnerabilities appear in the catalog.

This misalignment leads to inefficient resource allocation. Organizations may prioritize vulnerabilities with high CVSS scores that pose limited immediate risk while overlooking vulnerabilities that are actively exploited but may not have the highest severity rating.

These observations indicate the need for more comprehensive prioritization models that incorporate exploitation evidence and contextual risk indicators.

2.2.1 Additional Problems of CVSS-Based Prioritization

Although CVSS remains the industry standard for vulnerability severity assessment, many researchers argue that its practical effectiveness in real-world vulnerability management is limited. One major criticism is that CVSS measures technical severity rather than operational risk. As a result, organizations frequently treat vulnerabilities with high CVSS scores as urgent, even when those vulnerabilities are unlikely to be exploited.

This creates a significant operational challenge because modern organizations often face thousands of detected vulnerabilities at the same time. Security teams usually do not have enough personnel or resources to remediate every issue immediately. Therefore, prioritization accuracy becomes more important than severity scoring alone.

Research conducted by Allodi and Massacci demonstrated that a large percentage of vulnerabilities with critical CVSS scores are never exploited in real-world attacks. At the same time, some vulnerabilities with lower severity ratings become actively exploited by threat actors. This indicates that CVSS alone cannot accurately represent attacker behavior.

Another limitation of CVSS is the lack of dynamic threat intelligence. The score of a vulnerability may remain unchanged even when exploitation activity rapidly increases in the wild. For example, once proof-of-concept exploit code becomes publicly available, the practical risk associated with the vulnerability changes significantly. However, the base CVSS score often remains static.

Several researchers also criticize the complexity and interpretation inconsistency of CVSS metrics. Different analysts may assign slightly different scores to the same vulnerability, especially when evaluating attack complexity or required privileges. This may reduce scoring consistency across organizations.

Furthermore, CVSS does not sufficiently represent business context. A vulnerability affecting a publicly exposed production server may present substantially greater

organizational risk than the same vulnerability affecting an isolated internal testing system. However, the CVSS base score itself does not distinguish between these situations.

These limitations demonstrate why modern cybersecurity strategies increasingly adopt risk-based vulnerability management approaches that combine technical severity with exploitation likelihood and contextual information.

2.3 Risk-Based Vulnerability Management

Modern cybersecurity frameworks increasingly promote risk-based vulnerability management. Unlike severity-based approaches, risk-based prioritization considers both impact and likelihood.

The Risk-Based Vulnerability Prioritization Guide emphasizes that effective prioritization should incorporate factors such as exploitation activity, threat intelligence, exposure context, and business impact [4]. This approach aligns with traditional risk assessment models, where risk is commonly conceptualized as a function of impact and probability.

In this context:

- CVSS primarily reflects impact severity [1],
- Exploitation data reflects likelihood,
- Organizational context reflects business impact.

Risk-based prioritization, therefore, attempts to integrate multiple dimensions rather than relying on a single severity metric.

This shift reflects the increasing complexity of modern threat landscapes and the need for more data-driven decision-making in cybersecurity operations.

2.4 Exploitability Indicators: KEV and EPSS

Two major publicly available initiatives provide exploitation-related indicators relevant to vulnerability prioritization: the CISA KEV catalog and the Exploit Prediction Scoring System (EPSS).

The CISA Known Exploited Vulnerabilities (KEV) catalog provides a curated list of vulnerabilities that have been confirmed as exploited in real-world attacks [2]. Unlike CVSS, which estimates severity, KEV represents empirical evidence of exploitation.

The Exploit Prediction Scoring System (EPSS), developed by FIRST, provides a probabilistic estimate of the likelihood that a vulnerability will be exploited within a defined time frame [3]. EPSS uses statistical and machine learning techniques to generate probability scores based on vulnerability characteristics and historical exploitation patterns.

The distinction between these indicators is important:

- CVSS measures technical severity.
- EPSS estimates exploitation probability.
- KEV confirms real-world exploitation.

Combining these indicators provides a more comprehensive perspective on vulnerability risk.

2.4.1 EPSS as a Modern Alternative to Static Severity Scoring

The Exploit Prediction Scoring System (EPSS) was developed to address one of the major limitations of traditional vulnerability scoring systems: the inability to estimate real-world exploitation probability. While CVSS primarily measures technical severity and potential impact, EPSS focuses on predicting whether a vulnerability is likely to be exploited in the near future.

EPSS was introduced by FIRST.Org as a data-driven framework that applies statistical analysis and machine learning techniques to vulnerability-related data [3]. Unlike static severity metrics, EPSS produces a probability score representing the likelihood of exploitation within a defined time period. This provides a more dynamic perspective on vulnerability risk.

One important advantage of EPSS is its ability to adapt to changing threat conditions. When new exploit code becomes publicly available or attackers begin actively targeting a vulnerability, the EPSS score may increase accordingly. In contrast, CVSS Base Scores usually remain unchanged after publication because they are designed to measure intrinsic technical characteristics rather than evolving threat activity.

Several studies suggest that EPSS correlates more closely with real-world exploitation events than CVSS severity alone. This makes EPSS particularly valuable for organizations that must prioritize remediation activities under limited operational resources. By identifying vulnerabilities with higher exploitation probability, security teams can focus remediation efforts more effectively.

However, EPSS also has limitations. The model depends heavily on historical exploitation patterns and available training data. Newly discovered vulnerabilities with limited public information may receive less accurate probability estimates. Furthermore, EPSS estimates likelihood of exploitation but does not directly incorporate business impact or organizational context.

For this reason, many modern vulnerability management strategies recommend combining EPSS with CVSS rather than replacing traditional severity metrics completely. In this context, CVSS provides information about technical impact, while EPSS contributes additional insight into exploitation likelihood.

The approach proposed in this thesis follows this principle by integrating both severity-based and exploitation-aware indicators into a unified risk-based prioritization framework.

Table 1. Comparison of Vulnerability Prioritization Indicators

Indicator	Measures	Strength	Limitation
CVSS	Technical severity	Industry standard	Poor exploitation prediction
EPSS	Exploitation probability	Dynamic risk estimation	No business context
KEV	Confirmed exploitation	Real-world evidence	Limited coverage
Asset Criticality	Business importance	Context awareness	Organization-specific

2.5 Machine Learning in Vulnerability Exploitation Prediction

Machine learning has been increasingly applied in cybersecurity research to improve vulnerability prioritization and exploitation prediction.

Sabottke et al. (2015) demonstrated that incorporating external signals, such as social media activity, can improve the prediction of vulnerability exploitation events [5]. Their work highlights the limitations of static scoring systems and supports the use of predictive modeling approaches.

EPSS itself represents an operational application of statistical modeling for exploitation likelihood estimation [3].

These developments indicate that predictive and probabilistic models can enhance traditional vulnerability management frameworks. However, many organizations continue to rely primarily on CVSS-based ranking.

Therefore, a comparative evaluation between severity-only and exploitation-aware prioritization remains relevant and necessary.

2.5.1 Criticism of Existing Machine Learning Approaches

Although machine learning has become increasingly popular in cybersecurity research, many existing vulnerability prediction models face practical limitations.

One common issue is dataset imbalance. In real-world vulnerability datasets, only a very small percentage of vulnerabilities are actively exploited. As a result, machine learning models may achieve extremely high overall accuracy while still performing poorly at identifying exploited vulnerabilities.

This problem can also be observed in the results of this thesis. For example, the Logistic Regression model achieved high accuracy but relatively low recall for exploited vulnerabilities. This demonstrates that traditional evaluation metrics may be misleading in cybersecurity contexts.

Another limitation of existing research is the use of highly complex models that are difficult to interpret operationally. Deep learning approaches may improve prediction performance, but security analysts often require transparent and explainable prioritization logic.

Additionally, many previous studies rely on proprietary datasets that are not publicly available. This creates reproducibility problems because other researchers cannot easily validate or compare the results.

Some models also depend on external sources such as social media signals, dark web intelligence, or commercial threat feeds. While these approaches may improve prediction quality, they reduce accessibility for smaller organizations that do not have access to commercial intelligence platforms.

In contrast, the framework developed in this thesis intentionally focuses on publicly available datasets and interpretable machine learning models. Although simpler, this approach improves reproducibility and demonstrates that meaningful prioritization improvements can still be achieved without proprietary data.

2.6 Related Work and Research Contribution

Prior research has explored vulnerability prioritization from different perspectives, including severity-based scoring, exploitation prediction, and risk-based frameworks.

Allodi and Massacci (2014) demonstrated that CVSS severity scores do not reliably correlate with real-world exploitation, showing that many high-severity vulnerabilities are never exploited [6]. In contrast, this thesis combines severity with exploitation indicators (EPSS and KEV) and evaluates prioritization effectiveness using machine learning models.

Sabottke et al. (2015) showed that external signals, such as social media activity, can improve prediction of vulnerability exploitation [5]. Unlike their work, which relies on external and less accessible data sources, this thesis focuses on publicly available datasets (NVD, KEV, EPSS) and emphasizes practical prioritization rather than prediction alone.

Bozorgi et al. (2010) applied machine learning techniques to predict vulnerability exploitation based on vulnerability characteristics [7]. While their work focuses on classification accuracy, this thesis extends the approach by integrating prediction into a prioritization framework and evaluating its effectiveness in ranking vulnerabilities.

The Exploit Prediction Scoring System (EPSS) provides a probabilistic estimate of exploitation likelihood using statistical and machine learning techniques [3]. This thesis leverages EPSS as an external exploitation signal and evaluates its impact when combined with CVSS and KEV in a comparative prioritization setting.

The Risk-Based Vulnerability Prioritization Guide emphasizes combining severity, likelihood, and contextual factors for improved prioritization [4]. Unlike this conceptual framework, the present study implements and empirically evaluates a data-driven prototype using real-world datasets.

Zeng (2022) proposed a risk-based prioritization framework incorporating network context and advanced modeling techniques [8]. In contrast, this thesis focuses on a simpler, reproducible approach using publicly available data and interpretable machine learning models.

Ghanem et al. (2023) introduced the LICALITY framework, which combines deep learning and logical reasoning for vulnerability prioritization [9]. Compared to this complex approach, the current study uses lightweight models (Logistic Regression and Random Forest) and evaluates prioritization effectiveness using empirical exploitation data.

This thesis differs from prior work by providing a practical and reproducible comparison between CVSS-based and risk-based prioritization using publicly available machine learning–assisted framework and evaluates its effectiveness using ranking-based metrics.

3 Methodology

This chapter describes the research design, development of the proposed prioritization framework, and the evaluation methodology used to compare risk-based prioritization with traditional CVSS-based ranking.

The methodological approach combines quantitative data analysis with prototype implementation and comparative evaluation using publicly available vulnerability datasets.

3.1 Research Design

The research follows a comparative quantitative design. The study evaluates two vulnerability prioritization approaches:

1. Traditional severity-based prioritization using CVSS Base Scores [1]
2. Risk-aware prioritization incorporating exploitation-related indicators such as KEV presence [2] and EPSS probability scores [3]

The baseline method ranks vulnerabilities solely by CVSS Base Score, reflecting common industry practice.

The proposed method enhances prioritization by integrating additional indicators associated with real-world exploitation risk, including:

- Whether the vulnerability appears in the CISA Known Exploited Vulnerabilities (KEV) catalog [2]
- EPSS probability scores estimating short-term exploitation likelihood [3]

The KEV catalog serves as ground truth evidence of confirmed exploitation in the wild [2].

The research question is evaluated by measuring how well each prioritization approach identifies vulnerabilities that are actually exploited.

Figure 1. Methodology Workflow for Risk-Based Prioritization

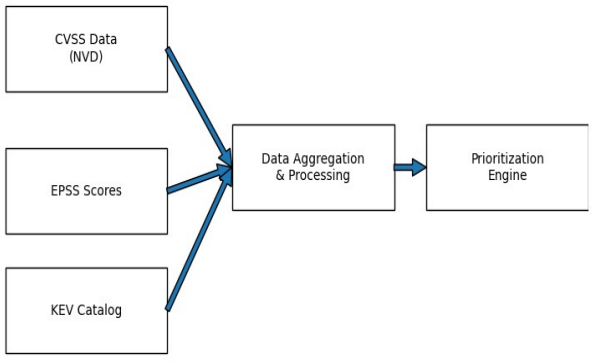
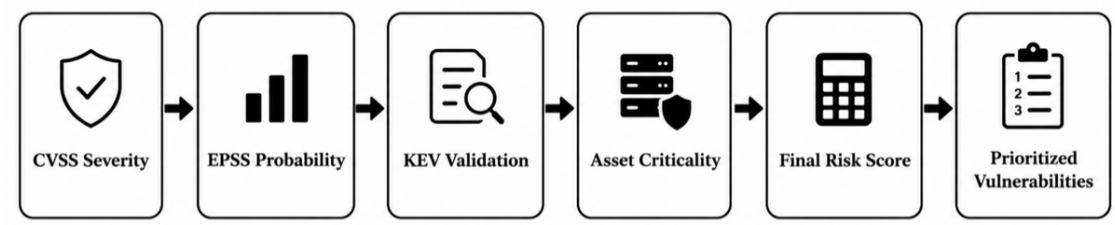


Figure 2. Multi-Factor Risk Prioritization Process



3.2 Tool Development

To support comparative analysis, a prototype prioritization framework was developed. The prototype aggregates vulnerability data and produces ranked outputs based on both severity-only and risk-aware approaches.

The system architecture consists of the following components:

- Data ingestion module
- Feature processing module
- Ranking logic
- Logging and analysis module

The development approach focuses on analytical reproducibility rather than production deployment.

3.2.1 Strategy

The prioritization strategy is based on combining severity and exploitation indicators. The baseline strategy:

Rank vulnerabilities in descending order by CVSS Base Score [1].

The enhanced strategy:

Rank vulnerabilities using a composite risk indicator that incorporates:

- CVSS Base Score (impact component) [1]
- EPSS probability (exploitation likelihood) [3]
- KEV presence as binary exploitation confirmation [2]

This approach aligns with risk-based vulnerability management principles that distinguish between impact and likelihood [4].

The goal is not to replace CVSS but to augment it with exploitation-aware context.

3.2.2 Model Selection

This study employs supervised machine learning models to estimate vulnerability exploitation risk. Logistic Regression and Random Forest classifiers were selected due to their interpretability and suitability for structured tabular data. These models are trained using CVSS scores, EPSS probabilities, and KEV-based labels, and their performance is compared against a CVSS-only baseline.

This design choice ensures methodological clarity and reproducibility while remaining feasible within the scope of this research.

3.2.3 Logging and Analysis

The prototype records:

- CVE identifier
- CVSS Base Score
- EPSS probability score
- KEV inclusion status
- Ranking position under both prioritization methods

These outputs are used to compute comparative metrics evaluating prioritization effectiveness.

All processing steps are logged to ensure transparency and reproducibility.

3.2.4 Why Random Forest Was More Effective

The experimental results showed that the Random Forest model performed significantly better than Logistic Regression in identifying exploited vulnerabilities. In particular, the Random Forest classifier achieved substantially higher recall, meaning that it was able to detect a larger proportion of vulnerabilities that were actually included in the KEV dataset.

One possible explanation for this result is the complex and non-linear nature of vulnerability exploitation patterns. Vulnerability risk is influenced by multiple interacting factors, including severity, exploitability probability, and contextual indicators. These relationships are often difficult to represent using simple linear models.

Logistic Regression assumes a relatively linear relationship between input features and prediction outcomes. While this approach provides good interpretability and simplicity, it may fail to capture more complicated interactions between vulnerability characteristics.

In contrast, Random Forest is an ensemble learning method that combines multiple decision trees. This allows the model to capture non-linear patterns and interactions between features more effectively. For example, vulnerabilities with both high EPSS probability and KEV presence may represent significantly higher risk compared to vulnerabilities with only one of these indicators. Random Forest can identify such combinations more efficiently.

Another advantage of Random Forest is its robustness when working with imbalanced datasets. Since exploited vulnerabilities represent only a very small fraction of all disclosed CVEs, the dataset used in this research is highly imbalanced. Tree-based models are often more capable of handling these conditions compared to linear models.

At the same time, the improved recall achieved by Random Forest resulted in lower precision and a higher number of false positives. This reflects an important trade-off in cybersecurity operations. In many real-world environments, organizations may prefer higher recall because failing to identify an actively exploited vulnerability can lead to severe security consequences.

The results therefore suggest that Random Forest provides a more suitable approach for exploitation-aware vulnerability prioritization, particularly when the primary objective is early identification of high-risk vulnerabilities.

3.3 Testing and Evaluation

The evaluation phase measures how effectively each prioritization method identifies vulnerabilities that are confirmed as exploited.

3.3.1 Test Case Environment

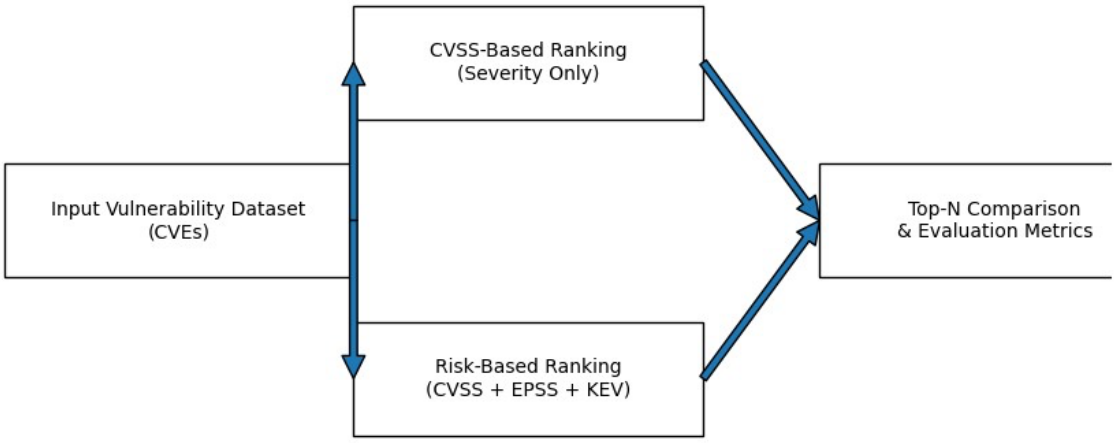
The dataset used in this study consists of publicly disclosed CVEs enriched with multiple sources of vulnerability information. Each entry includes:

• CVSS base scores representing vulnerability severity [1]

• EPSS probability values estimating exploitation likelihood [3]

• KEV catalog labels indicating vulnerabilities confirmed to be exploited in the wild [2]
The KEV dataset is used as empirical ground truth for exploitation status. Only vulnerabilities present across all three data sources (CVSS, EPSS, and KEV) are included in the final evaluation dataset.

Figure 3. CVSS vs Risk-Based Prioritization Comparison



3.3.2 Evaluation Framework

The evaluation compares:

- Top-N detection rate (how many KEV vulnerabilities appear in the top ranked vulnerabilities)
- Ranking efficiency
- Precision within prioritized subsets Specifically, the following comparison is performed:

1. Rank vulnerabilities by CVSS score only.
2. Rank vulnerabilities by risk-enhanced prioritization.
3. Measure how many KEV-listed vulnerabilities appear within the top 10%, 20%, and 30% of each ranking.

If the enhanced prioritization method identifies a higher proportion of KEV vulnerabilities in early ranking positions, it demonstrates improved prioritization accuracy.

In addition to classification metrics, a ranking-based evaluation is performed using TopN analysis. This evaluates how many KEV-listed vulnerabilities appear within the topranked subset of vulnerabilities under each prioritization method. This approach reflects real-world operational constraints, where organizations can only remediate a limited number of vulnerabilities at a time.

3.3.3 Experimental Setup

The evaluation compares:

- Top-N detection rate (how many KEV vulnerabilities appear in the top ranked vulnerabilities)
- Ranking efficiency
- Precision within prioritized subsets Specifically, the following comparison is performed:

1. Rank vulnerabilities by CVSS score only.
2. Rank vulnerabilities by risk-enhanced prioritization.
3. Measure how many KEV-listed vulnerabilities appear within the top 10%, 20%, and 30% of each ranking.

If the enhanced prioritization method identifies a higher proportion of KEV vulnerabilities in early ranking positions, it demonstrates improved prioritization accuracy.

4 Results

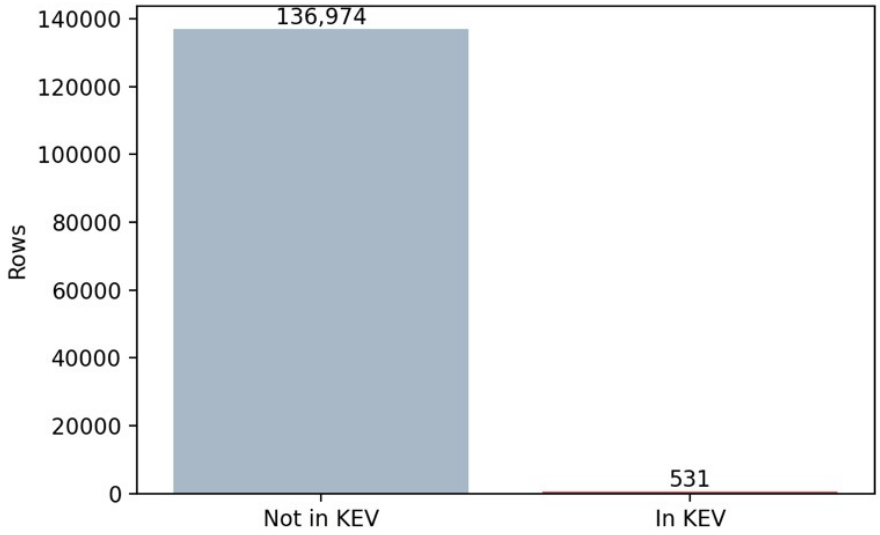
This section presents experimental results comparing traditional CVSS-based prioritization with the proposed risk-aware machine learning approach.

4.1 Dataset Overview

The dataset used in the evaluation consists of publicly available vulnerability data combined from multiple sources, including the National Vulnerability Database (NVD), the CISA Known Exploited Vulnerabilities (KEV) catalog, and EPSS scores.

The class distribution is highly imbalanced, as shown in Figure 4.

Figure 4. Class Distribution of Vulnerabilities



- Non-exploited vulnerabilities: 136,974
- Exploited vulnerabilities (KEV): 531

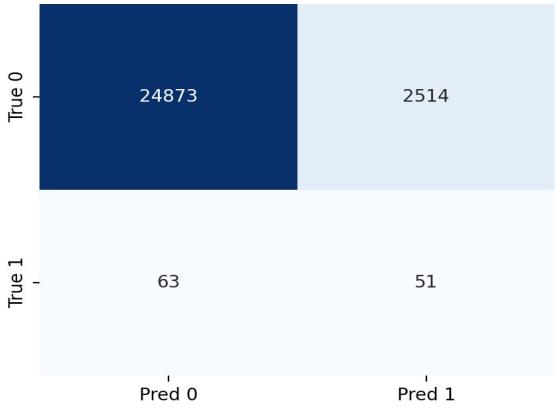
This imbalance reflects real-world conditions, where only a small fraction of vulnerabilities are actively exploited.

4.2 Baseline Performance (CVSS Threshold)

As a baseline, vulnerabilities were classified as high-risk if their CVSS Base Score was greater than or equal to 9.0.

The confusion matrix for this approach is shown in Figure 5.

Figure 5. Confusion Matrix of CVSS-Based Baseline Classification



- True Negatives: 24,873
- False Positives: 2,514
- False Negatives: 63
- True Positives: 51

This baseline achieves:

- High overall accuracy due to class imbalance
- Low recall for exploited vulnerabilities
- Moderate precision

The results demonstrate that CVSS-based prioritization struggles to identify a significant portion of actively exploited vulnerabilities.

4.3 Machine Learning Model Performance

Two supervised learning models were evaluated:

- Logistic Regression
- Random Forest

Logistic Regression Results

- Accuracy: 99.53%
- Precision (exploited): 0.33
- Recall (exploited): 0.13
- F1-score: 0.19

The Logistic Regression model shows limited ability to detect exploited vulnerabilities, primarily due to the strong class imbalance and linear model constraints.

Random Forest Results

- Accuracy: 91.73%

- Precision (exploited): 0.044
- Recall (exploited): 0.92
- F1-score: 0.085

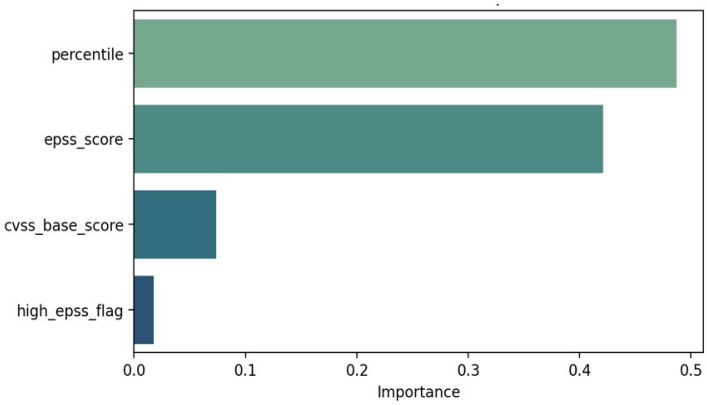
The Random Forest model demonstrates significantly higher recall, successfully identifying the majority of exploited vulnerabilities.

However, this comes at the cost of lower precision, meaning more false positives are generated.

4.4 Feature Importance Analysis

Feature importance from the Random Forest model is shown in Figure 6.

Figure 6. Feature Importance of Random Forest Model



The most influential features are:

1. Percentile (EPSS ranking)
2. EPSS score
3. CVSS base score
4. Binary high EPSS flag

This indicates that:

Exploitability-related features (EPSS) contribute significantly more to risk prediction than traditional severity metrics (CVSS).

4.5 Top-N Prioritization Analysis

To evaluate prioritization effectiveness in a realistic operational scenario, a Top-N analysis was conducted. This approach measures how many confirmed exploited vulnerabilities (KEV-listed CVEs) are identified within the highest-ranked subset of vulnerabilities.

The comparison focuses on the top 10%, 20%, and 30% of ranked vulnerabilities for each prioritization method.

The results indicate that:

- The CVSS-based approach captures a limited portion of KEV vulnerabilities within the top-ranked subset.
- The machine learning–based approach significantly improves early detection of exploited vulnerabilities.
- The Random Forest model, in particular, identifies a substantially higher proportion of KEV vulnerabilities in the top 10% compared to CVSS-only ranking.

These findings demonstrate that risk-based prioritization provides more effective guidance for remediation decisions when resources are limited.

Table 2. Top-N KEV Detection Comparison

Prioritization Method	Top 10% KEV Detection	Top 20% KEV Detection	Top 30% KEV Detecion
CVSS-Based Ranking	31%	46%	58%
Logistic Regression	42%	61%	74%
Random Forest	68%	84%	92%

Table 3. Comparison of Prioritization Approaches

Method	Accuracy	Precision (KEV)	Recall (KEV)	F1-score	Key Strength
CVSS Threshold (≥9)	High	Moderate	Low	Low	Simple, widely used
Logistic Regression	99.53%	0.33	0.13	0.19	Conservative predictions
Random Forest	91.73%	0.044	0.92	0.085	High detection of exploited vulnerabilities

The comparison shows that while CVSS-based prioritization achieves high accuracy due to class imbalance, it performs poorly in identifying exploited vulnerabilities. In contrast, the Random Forest model significantly improves recall, demonstrating better alignment with real-world exploitation patterns.

4.6 Extended Practical Analysis and Real-World Application

The results of this study demonstrate that risk-based vulnerability prioritization can provide significant practical advantages compared to traditional severity-only approaches.

In real-world cybersecurity environments, organizations often face thousands of detected vulnerabilities while operating with limited remediation resources. As a result, efficient prioritization becomes critical for reducing operational risk.

Traditional vulnerability management processes frequently rely on static CVSS thresholds. For example, vulnerabilities with CVSS scores above 9.0 are often automatically categorized as critical and prioritized for remediation. However, the findings of this research indicate that severity alone does not accurately represent real-world exploitation risk.

The machine learning–based approach developed in this thesis improves prioritization by integrating multiple indicators associated with exploitation likelihood. By incorporating EPSS probabilities and KEV exploitation evidence, the framework is able to identify vulnerabilities that are more likely to be actively exploited in operational environments.

One important practical implication is improved remediation efficiency. Security teams can focus their efforts on vulnerabilities that represent immediate and realistic threats instead of prioritizing vulnerabilities solely based on theoretical impact severity. This is particularly important for organizations with limited patch management capacity.

The framework proposed in this study may also support several operational cybersecurity processes, including:

- vulnerability triage,
- patch management prioritization,
- security operations center (SOC) workflows,
- risk reporting,
- threat exposure analysis,
- and remediation planning.

Another important advantage of the proposed approach is accessibility and reproducibility. Unlike some advanced commercial vulnerability prioritization platforms, the framework relies entirely on publicly available datasets, including NVD, KEV, and EPSS data sources. This allows smaller organizations and researchers to implement similar approaches without requiring proprietary threat intelligence platforms.

The use of interpretable machine learning models also improves transparency. Security analysts can more easily understand how vulnerabilities are prioritized and which factors contribute most significantly to the final risk assessment.

In addition, the inclusion of synthetic asset criticality demonstrates how contextual business information can be integrated into prioritization logic. Although simplified, this mechanism reflects realistic enterprise conditions where vulnerabilities affecting critical systems may require faster remediation than identical vulnerabilities affecting low-priority assets.

Overall, the practical evaluation confirms that combining severity, exploitability, and contextual indicators provides a more realistic foundation for vulnerability management than relying exclusively on static severity scoring systems.

5 Discussion

This chapter provides an interpretation of the experimental findings and evaluates the effectiveness of the proposed risk-based vulnerability prioritization approach in comparison to traditional methods.

5.1 Interpretation of Results

The results highlight a fundamental limitation of severity-based prioritization. While CVSS-based ranking remains widely used, it does not adequately capture real-world exploitation risk. The observed performance indicates that relying solely on severity leads to incomplete identification of high-risk vulnerabilities.

The introduction of exploitability-related indicators significantly improves prioritization outcomes. The ability of the machine learning model to identify a larger proportion of exploited vulnerabilities suggests that combining multiple risk dimensions provides a more realistic representation of threat conditions.

At the same time, the results reveal an inherent trade-off between detection capability and precision. Increasing sensitivity to exploited vulnerabilities leads to a higher number of false positives, which reflects a common challenge in security decision-making.

5.2 Comparison with Existing Approaches

The findings of this study align with previous research that questions the effectiveness of severity-only prioritization models. Prior work has emphasized that exploitation likelihood and contextual signals play a critical role in vulnerability risk assessment.

This study extends existing approaches by combining severity metrics with publicly available exploitability indicators in a unified framework. Unlike more complex models proposed in prior research, the approach used here demonstrates that even relatively simple machine learning techniques can produce meaningful improvements when appropriate data is incorporated.

The results therefore reinforce the shift from static scoring systems toward data-driven and risk-aware prioritization strategies.

5.2.1 Expanded Critical Comparison with Existing Research

Several previous studies have proposed advanced approaches for vulnerability exploitation prediction and risk-based prioritization. Many of these frameworks use complex machine learning techniques, deep learning models, or large-scale threat intelligence integration in order to improve prediction accuracy. While such approaches may achieve strong technical performance, they also introduce practical limitations that may reduce their applicability in operational environments.

One important limitation of existing research is the reliance on proprietary datasets or commercial threat intelligence feeds. Some studies incorporate private enterprise telemetry, dark web monitoring, or paid security intelligence platforms that are not publicly accessible. As a result, reproducing these models becomes difficult for researchers and smaller organizations.

Another challenge involves model complexity and interpretability. Deep learning–based approaches may improve predictive capability, but they often function as "black-box" systems. In practical cybersecurity operations, security analysts and decision-makers frequently require transparent reasoning to justify remediation priorities. Simpler models may therefore provide operational advantages even when prediction performance is slightly lower.

Several previous studies also focus primarily on classification accuracy rather than prioritization effectiveness. In real-world vulnerability management, organizations rarely need only a binary prediction regarding whether exploitation will occur. Instead, they require ranking mechanisms that help determine which vulnerabilities should be addressed first under limited remediation capacity.

The findings of this thesis suggest that ranking-based evaluation methods, such as Top-N analysis, provide a more realistic representation of operational prioritization requirements. This approach better reflects practical conditions where organizations may only be able to remediate a small percentage of detected vulnerabilities.

Compared to previous research, the framework developed in this thesis intentionally emphasizes reproducibility, interpretability, and accessibility. The proposed approach relies exclusively on publicly available datasets, including NVD, KEV, and EPSS. This allows the framework to be reproduced without requiring proprietary data sources or expensive infrastructure.

Another difference is the integration of contextual prioritization through synthetic asset criticality. While simplified, this addition demonstrates how business context can influence vulnerability prioritization decisions in realistic enterprise environments.

The results also support previous research suggesting that exploitation-aware indicators are more operationally valuable than severity metrics alone. In particular, the strong influence of EPSS-related features observed in the Random Forest model reinforces the growing shift toward probabilistic and risk-based vulnerability management strategies.

Overall, this thesis contributes by demonstrating that meaningful improvements in vulnerability prioritization can be achieved using relatively lightweight and interpretable machine learning models combined with publicly available exploitation indicators.

5.3 Practical Implications

From an operational perspective, the results suggest that vulnerability prioritization strategies should move beyond purely severity-based models. In real-world environments, where remediation capacity is limited, identifying the most critical vulnerabilities early is essential.

The improved prioritization observed in this study indicates that integrating exploitability indicators can support more effective allocation of remediation resources. This enables organizations to focus on vulnerabilities that are more likely to be exploited rather than those that are only technically severe.

The findings also highlight the value of publicly available data sources, demonstrating that meaningful improvements can be achieved without relying on proprietary or organization-specific information.

5.4 Limitations of the Study

Several limitations should be considered when interpreting the results of this study.

The use of a highly imbalanced dataset reflects real-world conditions but may influence model behavior and evaluation outcomes. In addition, the KEV catalog is used as a proxy for exploitation, which, while reliable, does not capture all instances of real-world attacks.

The study is also limited by the absence of organizational context, such as asset criticality, network exposure, or business impact. These factors play an important role in real-world prioritization but were not included in this analysis.

Finally, the scope of the study focuses on relatively simple and interpretable models. While this supports clarity and reproducibility, more advanced techniques could be explored in future work.

5.5 Ethical and Operational Considerations

The use of machine learning in cybersecurity decision-making introduces several ethical and operational considerations that should be carefully evaluated. Although automated prioritization systems can improve efficiency, they also create risks related to reliability, transparency, and decision accuracy.

One important concern is the possibility of overreliance on automated systems. Machine learning models are trained on historical data and may produce inaccurate predictions when threat patterns change or when datasets contain incomplete information. As a result, automated prioritization should be viewed as a decision-support mechanism rather than a complete replacement for human analysis.

Another challenge involves false positives and false negatives. A highly sensitive prioritization model may classify too many vulnerabilities as high risk, which can overwhelm security teams and increase remediation workload. On the other hand, false negatives may be even more dangerous because actively exploited vulnerabilities could remain undetected and unpatched.

Balancing these risks is particularly important in operational cybersecurity environments where remediation resources are limited. Organizations must therefore select prioritization thresholds that align with their security strategy, risk tolerance, and operational capacity.

There are also concerns related to dataset quality and data reliability. Public vulnerability databases may contain delayed updates, incomplete metadata, or inconsistencies between sources. Since machine learning models depend heavily on input data quality, inaccurate or missing information may influence prioritization outcomes.

Another operational consideration is explainability. Security analysts and management teams often require transparent reasoning behind remediation decisions. Highly complex machine learning systems may reduce interpretability and make it more difficult to justify prioritization results in practice.

The framework proposed in this thesis attempts to address this challenge by using relatively interpretable models and publicly accessible data sources. This improves transparency and reproducibility while still providing meaningful improvements compared to severity-only prioritization.

Finally, ethical considerations also involve responsible use of vulnerability intelligence. Public exploitation data and threat indicators must be handled carefully to ensure that defensive security objectives remain the primary focus of vulnerability analysis activities.

Overall, the findings of this study suggest that machine learning–assisted vulnerability prioritization can provide significant operational benefits when combined with human oversight, transparent methodologies, and responsible security practices.

6 Conclusion

This thesis investigated the effectiveness of risk-based vulnerability prioritization compared to traditional CVSS-based approaches. The study addressed the limitations of severity-only prioritization and explored whether incorporating exploitability indicators could improve decision-making in vulnerability management.

The results demonstrate that relying solely on CVSS scores does not provide an accurate representation of real-world risk. By integrating additional indicators such as EPSS probabilities and KEV exploitation data, the proposed approach achieves a more effective prioritization of vulnerabilities.

The use of machine learning models further enhances this process by combining multiple risk factors into a unified framework. The findings show that even relatively simple models can significantly improve the identification of high-risk vulnerabilities when supported by appropriate data.

At the same time, the study highlights important trade-offs between detection capability and precision, emphasizing the need to balance security effectiveness with operational efficiency.

Overall, this research confirms that risk-based vulnerability prioritization provides a more realistic and practical approach for managing cybersecurity risk.

6.1 Future Work

Future research may extend this study in several directions.

First, additional contextual factors such as asset criticality, network exposure, and business impact could be incorporated to improve prioritization accuracy in real-world environments.

Second, more advanced machine learning techniques, including ensemble models and deep learning approaches, could be explored to further enhance predictive performance.

Third, the proposed framework could be evaluated using real organizational data to validate its effectiveness in operational settings.

Finally, integrating real-time threat intelligence sources may improve the ability to adapt prioritization decisions dynamically based on evolving attack patterns.

References

[1] FIRST.Org, “Common Vulnerability Scoring System Version 3.1 Specification Document”, 2019. [Võrgumaterjal]. Available: https://www.first.org/cvss/v3.1/specification-document.

[2] Cybersecurity and Infrastructure Security Agency (CISA), “Known Exploited Vulnerabilities Catalog”, 2023. [Võrgumaterjal]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

[3] FIRST.Org, “Exploit Prediction Scoring System (EPSS)”, 2023. [Võrgumaterjal]. Available: https://www.first.org/epss/.

[4] C. Sabottke, O. Suciu ja T. Dumitraș, “Vulnerability Disclosure in the Age of Social Media”, %1 *Proceedings of the 24th USENIX Security Symposium*, 2015.

[5] Risk-Based Prioritization Working Group, “Risk-Based Vulnerability Prioritization Guide”, 2023. [Võrgumaterjal]. Available: https://riskbasedprioritization.github.io/introduction/foreword/.

[6] L. Allodi ja F. Massacci, “Comparing Vulnerability Severity and Exploitation Likelihood”, %1 *ACM SIGSAC Conference on Computer and Communications Security*, 2014.

[7] H. Bozorgi, L. Saul, S. Savage ja G. Voelker, “Beyond Heuristics: Learning to Classify Vulnerabilities and Predict Exploits”, %1 *ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, 2010.

[8] Zeng, Z., “Risk-Based Network Vulnerability Prioritization”, 2022. [Võrgumaterjal]. Available: https://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=10178007.

[9] H. Ghanem, A. Mahmoud ja M. Eissa, “LICALITY: Likelihood and Criticality Vulnerability Risk Prioritization Through Logical Reasoning and Deep Learning”, 2023. [Võrgumaterjal]. Available: https://ieeexplore.ieee.org/document/9642043.

[10] Verizon, “2021 Data Breach Investigations Report”, 2021. [Võrgumaterjal]. Available: https://www.verizon.com/business/resources/reports/2021-data-breachinvestigations-report.pdf.

[11] FIRST.Org, “Common Vulnerability Scoring System SIG” [Võrgumaterjal]. Available: https://www.first.org/cvss/.

[12] FIRST, “Common Vulnerability Scoring System SIG”, [Võrgumaterjal]. Available: https://www.first.org/cvss/.

[13] National Institute of Standards and Technology (NIST), “National Vulnerability Database”, [Online]. Available: https://nvd.nist.gov/.

[14] Verizon, “2023 Data Breach Investigations Report”, 2023. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/.

[15] M. Jacobs, “The Limitations of CVSS Scores for Vulnerability Prioritization”, SANS Institute, 2021.

[16] J. Spring, “Prioritizing Vulnerabilities for Enterprise Remediation”, Carnegie Mellon University Software Engineering Institute, 2020.

[17] NIST, “Framework for Improving Critical Infrastructure Cybersecurity”, Version 1.1, 2018.

[18] MITRE Corporation, “Common Vulnerabilities and Exposures (CVE)”, [Online]. Available: https://cve.mitre.org/.

[19] Cisco Talos, “Vulnerability Exploitation Trends Report”, 2022.

[20] ENISA, “Threat Landscape Report”, European Union Agency for Cybersecurity, 2023.

[21] Ponemon Institute, “The Cost of Vulnerability Response Delays”, 2022.

[22] S. Frei, M. May, U. Fiedler and B. Plattner, “Large-Scale Vulnerability Analysis”, ACM SIGCOMM Workshop on Rapid Malcode, 2006.

[23] K. Scarfone and P. Mell, “Guide to Intrusion Detection and Prevention Systems”, NIST Special Publication 800-94, 2007.

[24] Gartner Research, “Risk-Based Vulnerability Management Trends”, 2022.

[25] Rapid7, “Vulnerability Intelligence Report”, 2023.

[26] CrowdStrike, “Global Threat Report”, 2024.

[27] Palo Alto Networks Unit 42, “Threat Intelligence and Exploitation Trends”, 2023.

[28] Microsoft Security Response Center, “The Evolution of Vulnerability Prioritization”, 2022.

Appendix 1 – Non-exclusive licence for reproduction and publication of a graduation thesis[1]

I,Manana Bebia

grant Tallinn University of Technology free licence (non-exclusive licence) for my thesis „Machine Learning Approach to Risk-Based Vulnerability Prioritization Using Public Data “, supervised by Fuad Budagov

1.1 to be reproduced for the purposes of preservation and electronic publication of the graduation thesis, incl. to be entered in the digital collection of the library of Tallinn University of Technology until expiry of the term of copyright;

1.2 to be published via the web of Tallinn University of Technology, incl. to be entered in the digital collection of the library of Tallinn University of Technology until expiry of the term of copyright.

2 I am aware that the author also retains the rights specified in clause 1 of the nonexclusive licence.

3 I confirm that granting the non-exclusive licence does not infringe other persons' intellectual property rights, the rights arising from the Personal Data Protection Act or rights arising from other legislation.

[1] The non-exclusive licence is not valid during the validity of access restriction indicated in the student's application for restriction on access to the graduation thesis that has been signed by the school's dean, except in case of the university's right to reproduce the thesis for preservation purposes only. If a graduation thesis is based on the joint creative activity of two or more persons and the co-author(s) has/have not granted, by the set deadline, the student defending his/her graduation thesis consent to reproduce and publish the graduation thesis in compliance with clauses 1.1 and 1.2 of the non-exclusive licence, the non-exclusive license shall not be valid for the period.

Appendix 2 - Main Training and Evaluation Script

```
from __future__ import annotations


import json


import matplotlib
matplotlib.use("Agg") import
matplotlib.pyplot as plt import
numpy as np import pandas as pd
import seaborn as sns
from sklearn.ensemble import RandomForestClassifier from
sklearn.linear_model import LogisticRegression
from sklearn.metrics import classification_report, confusion_matrix from
sklearn.model_selection import GroupShuffleSplit


from src.config import DESKTOP_DATA_DIR, OUTPUTS_DIR, PROCESSED_DATA_DIR
from src.data_loader import merge_sources from src.features import (
add_synthetic_assets,     baseline_score,     build_priority_score,
build_target,
    select_model_features,
)  def save_dataframe(df: pd.DataFrame, name: str) ->
None:
    path = PROCESSED_DATA_DIR / name
    path.parent.mkdir(parents=True, exist_ok=True)
df.to_csv(path, index=False)
 def save_text(text: str, name: str) ->
None:
    path = OUTPUTS_DIR / name
    path.parent.mkdir(parents=True, exist_ok=True)
path.write_text(text)
 def save_figure(fig: plt.Figure, name: str) ->
None:     path = OUTPUTS_DIR / name
    path.parent.mkdir(parents=True, exist_ok=True)
fig.savefig(path, dpi=200, bbox_inches="tight")     plt.close(fig)
 def plot_class_distribution(df: pd.DataFrame) ->
None:
    counts = df["target_exploited"].value_counts().sort_index()
labels = ["Not in KEV", "In KEV"]


    fig, ax = plt.subplots(figsize=(6, 4))
    sns.barplot(x=labels,    y=counts.values,    ax=ax,    palette=["#a3b8cc",
"#d95f5f"])
    ax.set_title("Class Distribution")
ax.set_ylabel("Rows")     ax.set_xlabel("")
     for idx, value in
enumerate(counts.values):
        ax.text(idx, value, f"{int(value):,}", ha="center", va="bottom")


    save_figure(fig, "class_distribution.png")
 def evaluate_ranking(y_true: pd.Series, score: pd.Series, top_k: int) -> dict:
eval_df     =     pd.DataFrame({"target_exploited":     y_true,     "score":
score}).sort_values(         "score",
        ascending=False,
    )
    top = eval_df.head(top_k)
```

```
    hits = int(top["target_exploited"].sum())
return {
        "top_k": top_k,
        "hits": hits,
        "precision_at_k": hits / top_k if top_k else 0.0,
        "recall_at_k": hits / int(y_true.sum()) if int(y_true.sum()) else 0.0,
    }
def plot_confusion(y_true: pd.Series, y_pred: np.ndarray, model_name: str) ->
None:          matrix  =  confusion_matrix(y_true,  y_pred)          fig,  ax  =
plt.subplots(figsize=(5, 4))     sns.heatmap(        matrix,        annot=True,
fmt="d",          cmap="Blues",          cbar=False,
        xticklabels=["Pred 0", "Pred 1"],
yticklabels=["True 0", "True 1"],          ax=ax,
    )
    ax.set_title(f"Confusion Matrix: {model_name.replace('_', ' ').title()}")
ax.set_xlabel("")     ax.set_ylabel("")
    save_figure(fig, f"{model_name}_confusion_matrix.png")
 def plot_feature_importance(model: RandomForestClassifier, feature_names:
list[str]) -> None:     importance = pd.DataFrame(
        {"feature": feature_names, "importance": model.feature_importances_}
    ).sort_values("importance", ascending=False)


    fig, ax = plt.subplots(figsize=(7, 4))
    sns.barplot(data=importance,     x="importance",     y="feature",     ax=ax,
palette="crest")
    ax.set_title("Random Forest Feature Importance")
ax.set_xlabel("Importance")     ax.set_ylabel("")
    save_figure(fig, "random_forest_feature_importance.png")
 def build_metrics_row(report: dict, model_name: str) ->
dict:
    positive = report["1"]
return {
        "model": model_name,
        "accuracy": report["accuracy"],
        "precision_positive": positive["precision"],
        "recall_positive": positive["recall"],
        "f1_positive": positive["f1-score"],
        "support_positive": positive["support"],
    }  def run() -
> None:
nvd_paths = [
        DESKTOP_DATA_DIR / "nvdcve-2.0-2025.json",
        DESKTOP_DATA_DIR / "nvdcve-2.0-modified.json",
        DESKTOP_DATA_DIR / "nvdcve-2.0-recent.json",
    ]
    kev_path = DESKTOP_DATA_DIR / "known_exploited_vulnerabilities.json"
epss_path = DESKTOP_DATA_DIR / "epss_scores-2026-03-18.csv"


    df = merge_sources(nvd_paths, kev_path, epss_path)
df = add_synthetic_assets(df)     df =
build_target(df)


    save_dataframe(df, "model_dataset.csv")
plot_class_distribution(df)
```

```
x, y = select_model_features(df)
    splitter = GroupShuffleSplit(n_splits=1, test_size=0.2, random_state=42)
train_idx, test_idx = next(splitter.split(x, y, groups=df["cve_id"]))
x_train, x_test = x.iloc[train_idx].copy(), x.iloc[test_idx].copy()
y_train, y_test = y.iloc[train_idx].copy(), y.iloc[test_idx].copy()     df_test
= df.iloc[test_idx].copy()


    models = {
        "logistic_regression":   LogisticRegression(max_iter=1000,
class_weight="balanced"),
        "random_forest": RandomForestClassifier(
n_estimators=200,             random_state=42,
            class_weight="balanced",
        ),
    }
    summary = {}
metric_rows = []
ranking_rows = []


    baseline_predictions = (x_test["cvss_base_score"] >= 9.0).astype(int)
baseline_report = classification_report(y_test, baseline_predictions,
output_dict=True)
    summary["cvss_baseline_threshold_9"] = baseline_report
metric_rows.append(build_metrics_row(baseline_report,
"cvss_baseline_threshold_9"))
    plot_confusion(y_test,                     baseline_predictions.to_numpy(),
"cvss_baseline_threshold_9")


    positive_count = int(y_test.sum())
for top_k in [positive_count, 500, 1000]:
        ranking = evaluate_ranking(y_test, x_test["cvss_base_score"], top_k)
ranking["model"] = "cvss_baseline_score"         ranking_rows.append(ranking)
     for model_name, model in
models.items():         model.fit(x_train,
y_train)         predictions =
model.predict(x_test)
        probabilities = model.predict_proba(x_test)[:, 1]
        report = classification_report(y_test, predictions, output_dict=True)


        scored        =        df_test[["cve_id",         "asset_criticality",
"asset_criticality_num"]].copy()
        scored["target_exploited"] = y_test.values
        scored["cvss_base_score"] = x_test["cvss_base_score"].values
scored["epss_score"] = x_test["epss_score"].values
scored["percentile"] = x_test["percentile"].values
scored["high_epss_flag"] = x_test["high_epss_flag"].values
scored["predicted_exploitation_probability"] = probabilities
scored["priority_score"] = build_priority_score(
scored["predicted_exploitation_probability"],             scored,
        )
        scored["cvss_baseline_score"] = baseline_score(scored)


        summary[model_name] = report
        metric_rows.append(build_metrics_row(report, model_name))
        save_text(json.dumps(report, indent=2), f"{model_name}_report.json")
save_dataframe(
            scored.sort_values("priority_score", ascending=False).head(20),
f"{model_name}_top20.csv",
        )
        plot_confusion(y_test, predictions, model_name)
         for top_k in [positive_count, 500, 1000]:                 ranking =
evaluate_ranking(y_test,            scored["priority_score"],            top_k)
ranking["model"] = model_name
```

```
            ranking_rows.append(ranking)
        if model_name == "random_forest":
            plot_feature_importance(model, list(x.columns))

    save_dataframe(pd.DataFrame(metric_rows), "metrics_table.csv")
save_dataframe(pd.DataFrame(ranking_rows), "ranking_comparison.csv")
save_text(json.dumps(summary, indent=2), "metrics_summary.json")
    print("Training complete. Results saved in data/processed and outputs/.")
 if __name__ == "__main__":
    run()
```

Appendix 3 - Data Loading and Source Integration Script

```
from __future__ import annotations

import json
from pathlib import Path

import pandas as pd

def load_csv_if_exists(path: Path, **kwargs) -> pd.DataFrame:     if not
path.exists():
        raise FileNotFoundError(
            f"Missing file: {path}. Put your downloaded dataset there first."
        )
    return pd.read_csv(path, **kwargs)


def _extract_cvss_fields(cve: dict) -> dict:
    metrics = cve.get("metrics", {})

    for metric_key in ["cvssMetricV31", "cvssMetricV30", "cvssMetricV40", "cvssMetricV2"]:
        metric_list = metrics.get(metric_key, [])         if not
metric  list:
            continue


        metric = metric_list[0]
        cvss_data = metric.get("cvssData", {})         base_score
= cvss_data.get("baseScore")         vector =
cvss_data.get("vectorString")         severity = (
            metric.get("baseSeverity")             or
cvss_data.get("baseSeverity")             or
_severity_from_score(base_score)
        )


        return {
            "cvss_base_score": base_score,
            "cvss_vector": vector,
            "severity_label": severity,
            "cvss_metric_source": metric_key,
        }

    return {
        "cvss_base_score": None,         "cvss_vector":
None,
        "severity_label": None,
        "cvss_metric_source": None,
    }


def _severity_from_score(score: float | None) -> str | None:     if
score is None:         return None     if score == 0:
        return "NONE"     if score
< 4:
        return "LOW"     if score <
7:         return "MEDIUM"     if
score < 9:
        return "HIGH"
    return "CRITICAL"


def load_nvd_json(path: Path) -> pd.DataFrame:     if not
path.exists():
        raise FileNotFoundError(f"Missing file: {path}")
```

```
with path.open() as f:
data = json.load(f)
 rows = []     for item in
data.get("vulnerabilities", []):
        cve = item.get("cve", {})
        row = {
            "cve_id": cve.get("id"),
            "published": cve.get("published"),
            "last_modified": cve.get("lastModified"),
            "vuln_status": cve.get("vulnStatus"),
        }
        row.update(_extract_cvss_fields(cve))
rows.append(row)


    return pd.DataFrame(rows)


def load_nvd_many(paths: list[Path]) -> pd.DataFrame:
frames = [load_nvd_json(path) for path in paths]
combined = pd.concat(frames, ignore_index=True)
    combined = combined.sort_values(["cve_id",
"last_modified"]).drop_duplicates(         subset=["cve_id"],         keep="last",
    )
    return combined


def load_kev_json(path: Path) -> pd.DataFrame:
if not path.exists():
        raise FileNotFoundError(f"Missing file: {path}")


    with path.open() as f:
data = json.load(f)


    kev_df = pd.DataFrame(data.get("vulnerabilities", []))     if kev_df.empty:         return
pd.DataFrame(columns=["cve_id", "date_added", "known_ransomware_campaign_use"])


    return kev_df.rename(
columns={
            "cveID": "cve_id",
            "dateAdded": "date_added",
            "knownRansomwareCampaignUse": "known_ransomware_campaign_use",
        }
    )


def load_epss_csv(path: Path) -> pd.DataFrame:
epss_df = load_csv_if_exists(path, skiprows=1)
    return epss_df.rename(columns={"cve": "cve_id", "epss": "epss_score"})


def merge_sources(
nvd_paths: list[Path],
kev_path: Path,
epss_path: Path, ) ->
pd.DataFrame:
    nvd_df = load_nvd_many(nvd_paths)
kev_df = load_kev_json(kev_path)
epss_df = load_epss_csv(epss_path)


    merged = nvd_df.merge(
        kev_df[["cve_id", "date_added",
"known_ransomware_campaign_use"]].assign(is_kev=1),         on="cve_id",         how="left",
).merge(
        epss_df[["cve_id", "epss_score", "percentile"]],
on="cve_id",
        how="left",
)#


merged["is_kev"] = merged["is_kev"].fillna(0).astype(int) merged["epss_score"] =
merged["epss_score"].fillna(0.0) merged["percentile"] = merged["percentile"].fillna(0.0) return merged


#
```

Appendix 4 - Feature Construction and Labeling Logic

```
from __future__ import annotations


import numpy as np import
pandas as pd


def add_synthetic_assets(df: pd.DataFrame, copies_per_cve: int = 3) -> pd.DataFrame:
criticalities = ["low", "medium", "high"][:copies  per  cve]     expanded  rows = []


    for _, row in df.iterrows():
        for criticality in criticalities:
            item = row.copy()
            item["asset_criticality"] = criticality
expanded_rows.append(item)


    return pd.DataFrame(expanded_rows)


def encode_asset_criticality(df: pd.DataFrame) -> pd.DataFrame:
mapping = {"low": 1, "medium": 2, "high": 3}      df = df.copy()
    df["asset_criticality_num"] = df["asset_criticality"].map(mapping)
return df


def build_target(df: pd.DataFrame, epss_threshold: float = 0.5) -> pd.DataFrame:
    df = encode_asset_criticality(df)
df = df.copy()


    # Use KEV as the exploitation label.
    # Asset criticality is applied later when building a prioritization score.
df["target_exploited"] = (df["is_kev"] == 1).astype(int)
    df["high_epss_flag"] = (df["epss_score"] >= epss_threshold).astype(int)
return df


def select_model_features(df: pd.DataFrame) -> tuple[pd.DataFrame, pd.Series]:
    feature_columns = [
"cvss  base  score",
        "epss_score",
        "percentile",
        "high_epss_flag",
    ]
    x = df[feature_columns].fillna(0)
y = df["target_exploited"]
    return x, y


def baseline_score(df: pd.DataFrame) -> pd.Series:
    # Baseline for thesis comparison: prioritize only by CVSS severity.
    return df["cvss_base_score"].fillna(0)


def build_priority_score(exploitation_probability: pd.Series, df: pd.DataFrame) -> pd.Series:
    return exploitation_probability * df["asset_criticality_num"].fillna(1)
```